

Sécurité des réseaux

Projet MediConnect - Sécurisation de l'infrastructure réseau d'une plateforme de prise de rendez-vous médicaux

Promo 2028
Étudiants : El Assad SAID - Yves de KERROS
Professeur : Salim BENAYOUNE
2026-2027

Vidéo de démonstration : https://drive.google.com/file/d/1FtXBzEagIfHcMOEVBhN16rlT7ti5lHTe/view

Sommaire

Introduction 3

1. Architecture retenue 3

2. Plan d'adressage 5

3. Zones de sécurité 6

4. Niveau de confiance par zone 7

5. VPN utilisés 8

5.1 Interconnexion des sites : IPsec IKEv2 8

5.2 Accès distant des employés : OpenVPN télétravail 9

5.3 Accès des commerciaux itinérants : OpenVPN dédié 10

6. Mécanismes d'authentification 12

Accès renforcé des médecins (certificat client) 15

7. Politique de filtrage 15

8. Règles basées sur l'identité 18

9. Contrôle applicatif 20

10. Protection de la DMZ 20

11. Sécurisation de l'administration 22

12. Stratégie de journalisation 23

13. Tests réalisés 25

14. Limites de la solution 26

Introduction

MediConnect est une société fictive qui exploite une plateforme de prise de rendez-vous médicaux. Le sujet demande de concevoir et de mettre en oeuvre la sécurité réseau de son infrastructure : deux sites, une plateforme exposée sur Internet, une zone de démonstration séparée de la production, et cinq populations d'utilisateurs (patients, médecins, employés en télétravail, commerciaux itinérants, administrateurs). L'application elle-même n'est pas développée : un serveur web simple joue le rôle du portail.

Le projet a été réalisé en binôme sur une maquette virtuelle (VMware). Ce rapport décrit les choix d'architecture, les mécanismes mis en place, leur justification et les tests qui les valident. Les numéros de captures renvoient aux copies d'écran incluses dans le document.

Résultat. Tous les éléments demandés sont réalisés et testés : pare-feu du siège et ses zones, portail en DMZ, serveur interne, site secondaire relié par IPsec, annuaire LDAP, autorité de certification, accès distant des employés en télétravail et des commerciaux avec règles par identité, accès renforcé des médecins par certificat client, journalisation centralisée et durcissement de l'administration. Les limites de la maquette sont présentées en section 14.

1. Architecture retenue

L'architecture repose sur un pare-feu pfSense CE 2.9.0 au siège, qui porte à lui seul toute la segmentation : une interface par zone de sécurité, un jeu de règles par interface et un refus par défaut. Un second pfSense protège le site secondaire. Les deux sites sont reliés par un tunnel IPsec ; les utilisateurs distants se connectent au siège par deux serveurs OpenVPN (télétravail et commerciaux). Internet est simulé par un segment réseau 203.0.113.0/24 sur lequel se trouvent les WAN des deux sites et la machine Kali, qui joue tour à tour le patient, le télétravailleur et l'attaquant.

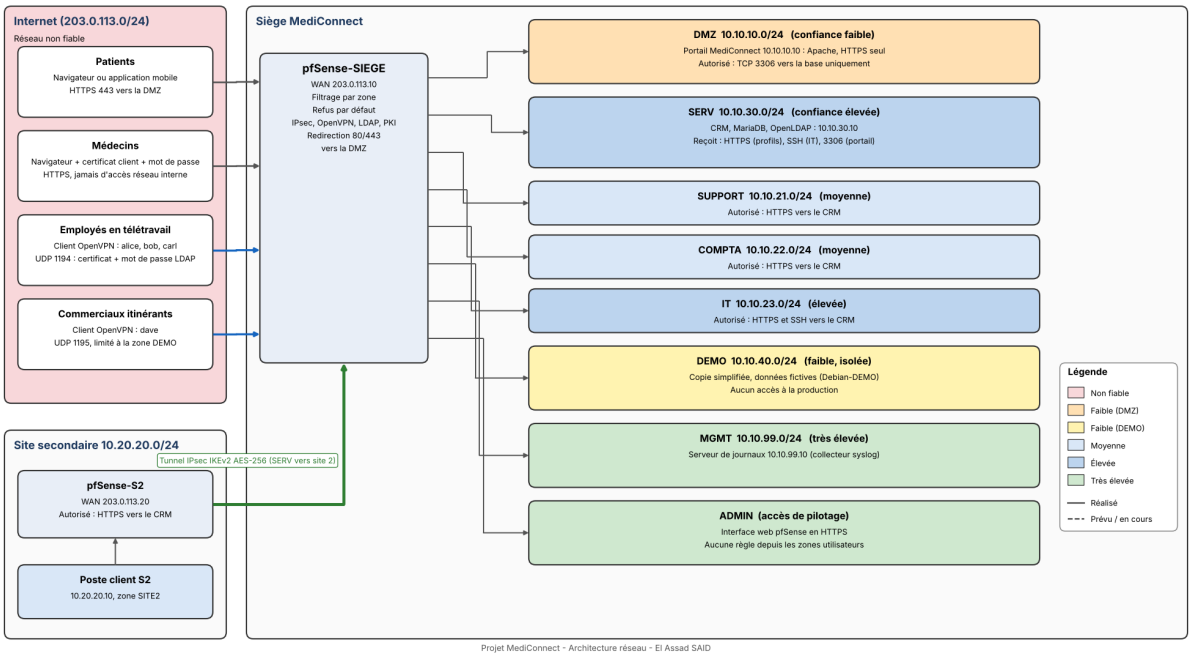
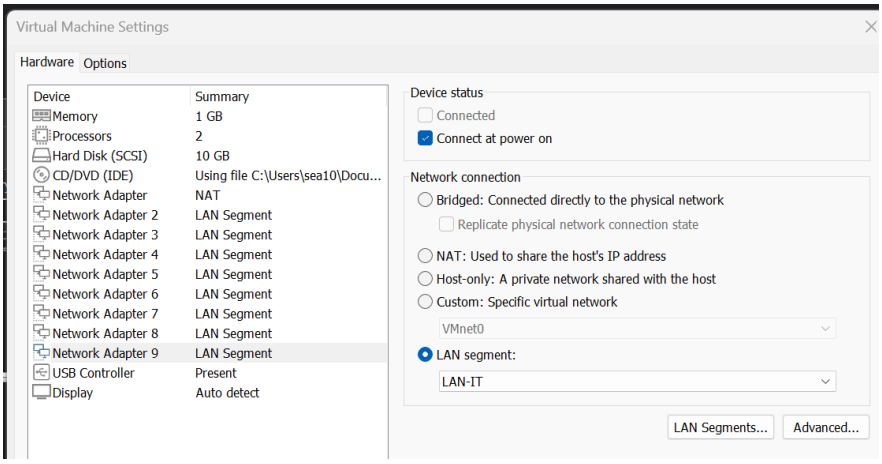


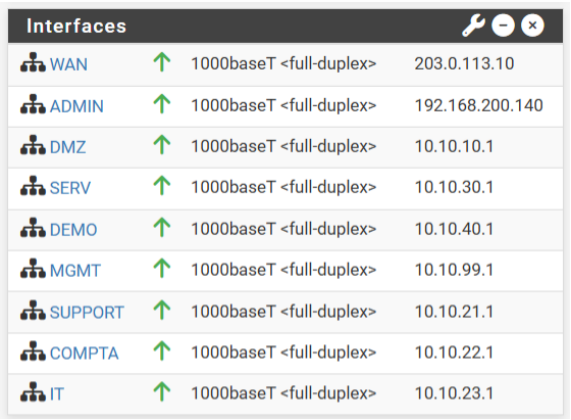
Schéma d'architecture de MediConnect

Justification. Un pare-feu unique avec une interface par zone permet de contrôler explicitement chaque flux entre deux zones, sans dépendre d'un filtrage par VLAN sur des commutateurs. pfSense fournit sur la même plateforme le filtrage à états, la redirection de ports, IPsec, OpenVPN, l'authentification LDAP et une autorité de certification, ce qui limite le nombre d'équipements à administrer.

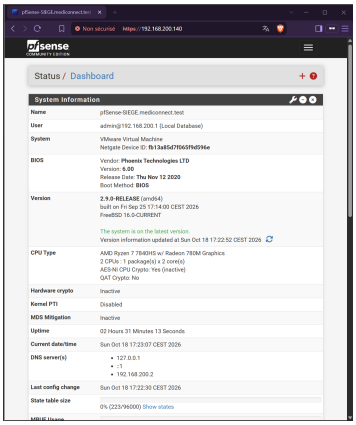
Machine	Rôle	Zone
pfSense-SIEGE	Pare-feu, passerelle VPN, autorité de certification	9 interfaces (voir section 3)
pfSense-S2	Pare-feu du site secondaire, extrémité du tunnel IPsec	WAN, SITE2, administration
Debian-PORTAIL	Portail MediConnect (Apache, HTTPS)	DMZ
Debian-CRM	CRM, base de données MariaDB, annuaire OpenLDAP	SERV
Client S2	Poste d'un employé du site secondaire	SITE2
Kali	Patient, télétravailleur, commercial, attaquant, selon le test	Internet simulé



Capture 18 : Réglages VMware de pfSense-SIEGE : neuf cartes réseau (NAT, Internet, DMZ, SERV, DEMO, MGMT, LAN-SUPPORT, LAN-COMPTA, LAN-IT), une par zone



Capture 22 : Tableau de bord pfSense-SIEGE, widget Interfaces : les 9 zones avec leur adresse (WAN 203.0.113.10, ADMIN 192.168.200.140, DMZ 10.10.10.1, SERV 10.10.30.1, DEMO 10.10.40.1, MGMT 10.10.99.1, SUPPORT 10.10.21.1, COMPTA 10.10.22.1, IT 10.10.23.1), toutes up



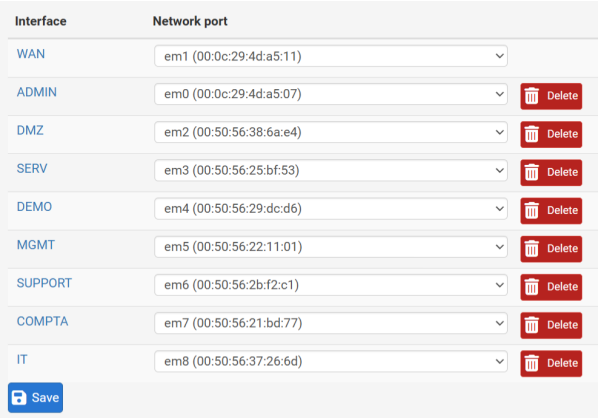
Capture 6 : Tableau de bord pfSense-SIEGE (pfSense CE 2.9.0, nom pfSense-SIEGE.mediconnect.test) accessible en HTTPS depuis le poste d'administration

2. Plan d'adressage

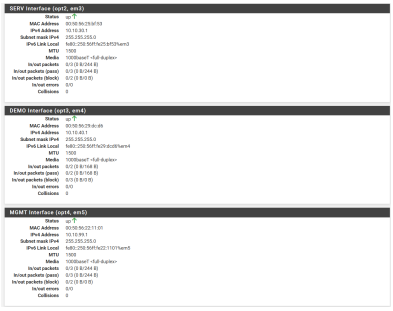
Chaque zone dispose d'un sous-réseau /24 distinct, ce qui permet d'écrire des règles par zone et de résumer l'ensemble des réseaux internes dans un alias (10.10.0.0/16, 10.20.20.0/24 et 10.99.0.0/16). Le plan est le suivant.

Réseau	Adresses	Passerelle / hôtes
Internet simulé	203.0.113.0/24	WAN siège .10, WAN site 2 .20, Kali .100
DMZ	10.10.10.0/24	pfSense .1, portail .10
SUPPORT / COMPTA / IT	10.10.21.0/24, 10.10.22.0/24, 10.10.23.0/24	pfSense .1
SERV (serveurs internes)	10.10.30.0/24	pfSense .1, CRM, base et LDAP .10
DEMO	10.10.40.0/24	pfSense .1
MGMT (management)	10.10.99.0/24	pfSense .1, serveur de logs .10
Site secondaire	10.20.20.0/24	pfSense .1, client .10
VPN télétravail	10.99.10.0/24	alice .11, bob .12, carl .13
VPN commerciaux	10.99.20.0/24	adresses fixes par utilisateur
Administration (provisoire)	192.168.200.0/24 (NAT VMware)	siège .140, site 2 .148

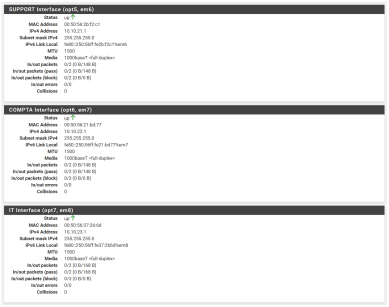
Le tunnel IPsec étant défini par politique, il n'utilise pas de réseau de transit dédié : seul le trafic entre les réseaux déclarés dans la phase 2 est chiffré. Les adresses de gestion en NAT servent uniquement à piloter les pare-feux depuis le poste de travail pendant la maquette.



Capture 19 : Interfaces > Assignments de pfSense-SIEGE : WAN, ADMIN, DMZ, SERV, DEMO, MGMT, SUPPORT, COMPTA, IT, chacune sur son port (em0 à em8) avec son adresse MAC



Capture 20 : Status > Interfaces : SERV 10.10.30.1/24, DEMO 10.10.40.1/24, MGMT 10.10.99.1/24, toutes up

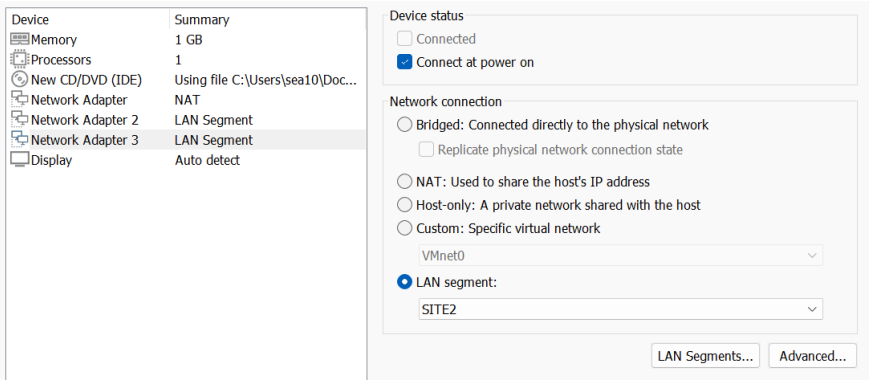


Capture 21 : Status > Interfaces : SUPPORT 10.10.21.1/24, COMPTA 10.10.22.1/24, IT 10.10.23.1/24, toutes up

3. Zones de sécurité

Neuf zones sont définies au siège et une au site secondaire. Le découpage suit le principe du moindre privilège : un groupe d'utilisateurs ou de machines ayant le même besoin et le même niveau de risque partage une zone.

Zone	Contenu	Raison d'être
WAN	Interface Internet du pare-feu	Point d'entrée unique des patients, médecins et VPN
DMZ	Portail MediConnect	Service exposé, isolé du réseau interne
SERV	CRM, base de données, annuaire LDAP	Données et services sensibles
SUPPORT, COMPTA, IT	Postes des équipes	Droits distincts par métier
DEMO	Copie simplifiée avec données fictives	Démonstrations devant les médecins, séparée de la production
MGMT	Serveur de journaux	Flux d'administration et de supervision séparés des flux utilisateurs
ADMIN	Accès provisoire de pilotage (NAT)	Interface de gestion hors des zones utilisateurs
SITE2	Employés du site secondaire	Atteignent le siège par le tunnel IPsec



Capture 42 : Réglages VMware de pfSense-S2 (1 Go de mémoire, 3 cartes) : carte 3 sur le LAN Segment SITE2 (réseau local du site secondaire)

4. Niveau de confiance par zone

Chaque zone reçoit un niveau de confiance qui détermine ce qu'elle a le droit d'atteindre. La règle générale est qu'une zone ne peut initier un flux que vers une zone de niveau supérieur ou égal si un besoin métier le justifie, et jamais vers le management.

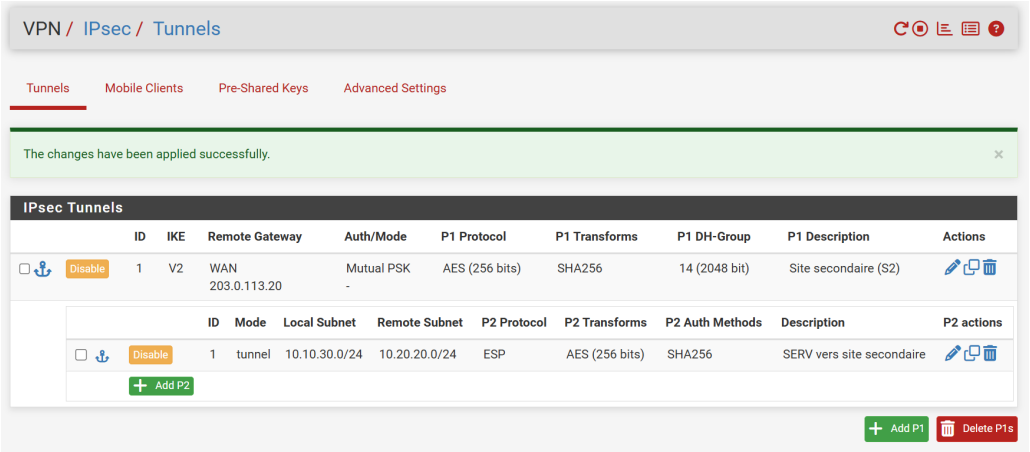
Zone	Confiance	Justification	Flux autorisés
Internet	Nulle	Réseau public, patients et attaquants non distinguables	HTTPS vers la DMZ, tunnels VPN
DMZ	Faible	Exposée, donc la plus susceptible d'être compromise	Base de données (3306) uniquement
DEMO	Faible	Données fictives, présentée à des tiers	Aucun accès à la production
SUPPORT, COMPTA	Moyenne	Postes d'employés, usage restreint	HTTPS vers le CRM
IT	Élevée	Personnel technique	HTTPS et SSH vers le CRM
SERV	Élevée	Contient les données	Aucun flux initié vers l'extérieur
MGMT	Très élevée	Journaux et administration	Accessible seulement par la zone d'administration
Site secondaire	Moyenne	Employés, relié par un tunnel authentifié	HTTPS vers le CRM par IPsec

5. VPN utilisés

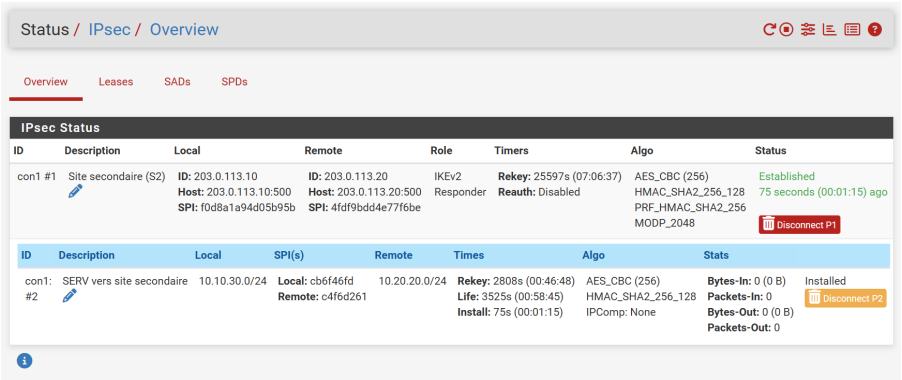
Trois usages distincts, trois configurations adaptées.

5.1 Interconnexion des sites : IPsec IKEv2

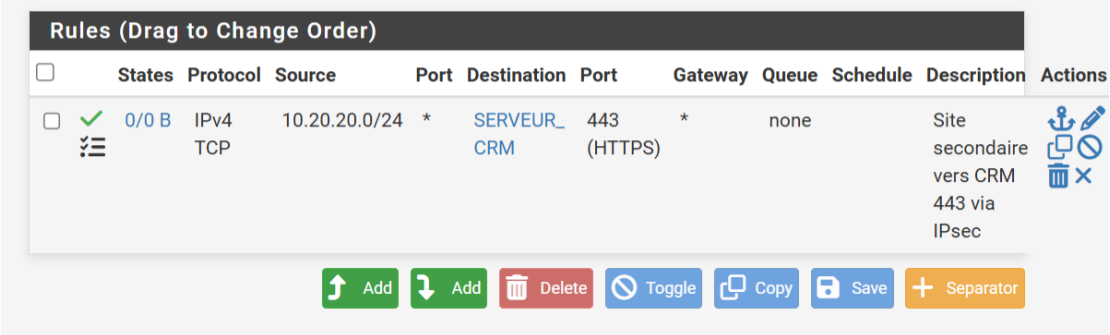
Les deux pare-feux établissent un tunnel IKEv2 avec une clé pré-partagée mutuelle. Phase 1 : AES-256, SHA-256, groupe Diffie-Hellman 14. Phase 2 en mode tunnel, ESP AES-256 / SHA-256, **limitée au réseau serveurs 10.10.30.0/24 et au site secondaire 10.20.20.0/24** : le tunnel n'ouvre donc pas l'ensemble du siège aux employés du site 2. Le site 2 n'atteint que le HTTPS du CRM, par une règle sur chaque pare-feu.



Capture 49 : VPN > IPsec > Tunnels de pfSense-SIEGE : phase 1 IKEv2, WAN vers 203.0.113.20, Mutual PSK, AES 256 / SHA256 / DH 14 ; phase 2 en mode tunnel, SERV 10.10.30.0/24 vers 10.20.20.0/24, ESP AES-256 / SHA256 (aucune clé visible)



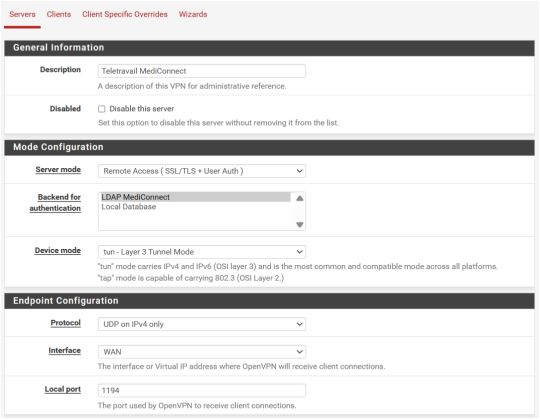
Capture 51 : Status > IPsec de pfSense-SIEGE avec la child SA dépliée : tunnel ESTABLISHED, phase 2 « SERV vers site secondaire » 10.10.30.0/24 vers 10.20.20.0/24, AES_CBC 256 / HMAC_SHA2_256, état Installed (compteurs à 0 : avant tout trafic)



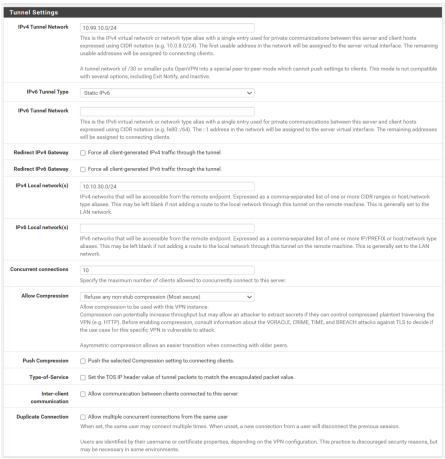
Capture 52 : Firewall > Rules > IPsec de pfSense-SIEGE : Pass TCP depuis 10.20.20.0/24 (site secondaire) vers SERVEUR_CRM port 443 uniquement

5.2 Accès distant des employés : OpenVPN télétravail

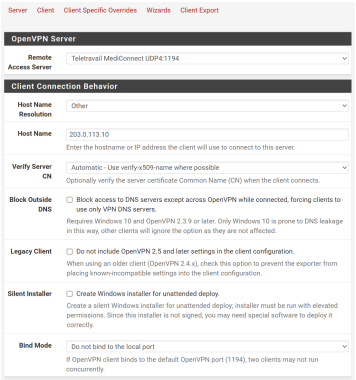
Le serveur OpenVPN écoute en UDP 1194 sur le WAN. Chaque connexion exige **deux éléments** : un certificat client signé par l'autorité interne et un identifiant/mot de passe vérifié dans l'annuaire LDAP, avec contrôle que le nom du certificat correspond à l'identifiant (Strict User-CN Matching). Le tunnel utilise 10.99.10.0/24, ne redirige pas la passerelle du client, n'annonce que le réseau serveurs, refuse la compression et la communication entre clients. Des paramètres propres à chaque utilisateur lui attribuent une adresse fixe, base de la politique par identité (section 8).



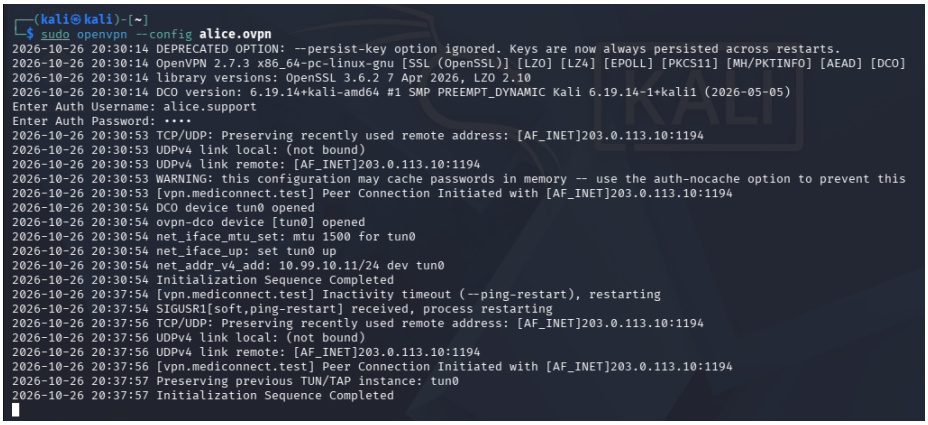
Capture 63 : Serveur OpenVPN « Teletravail MediConnect » : mode Remote Access (SSL/TLS + User Auth), authentification par le serveur « LDAP MediConnect », tun, UDP IPv4, interface WAN, port 1194



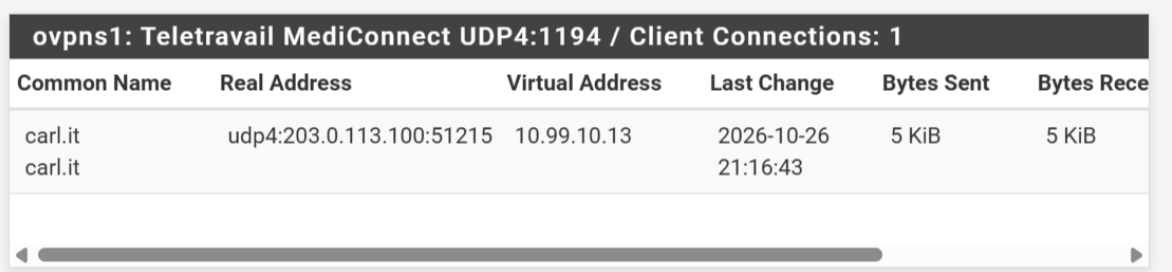
Capture 65 : Serveur OpenVPN Télétravail, réglages du tunnel : réseau 10.99.10.0/24, pas de redirection de la passerelle, seul réseau accessible 10.10.30.0/24 (SERV), 10 connexions maximum, compression refusée, pas de communication entre clients, pas de connexions multiples d'un même utilisateur



Capture 74 : VPN > OpenVPN > Client Export : serveur « Teletravail MediConnect UDP4:1194 », nom d'hôte 203.0.113.10 (WAN du siège), vérification du CN du serveur automatique



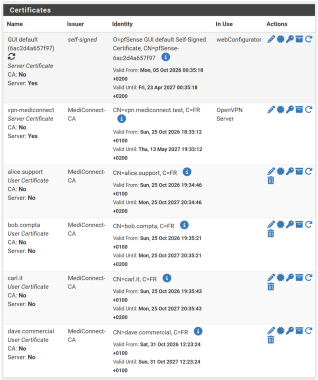
Capture 75 : Kali (Internet simulé) : connexion OpenVPN d'alice.support (LDAP + certificat), « Initialization Sequence Completed », adresse tunnel 10.99.10.11



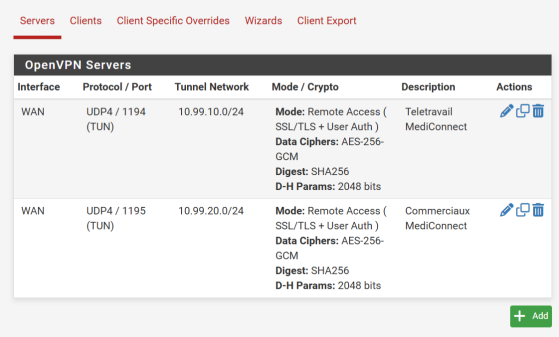
Capture 79 : Status > OpenVPN : client carl.it connecté (203.0.113.100, adresse virtuelle 10.99.10.13)

5.3 Accès des commerciaux itinérants : OpenVPN dédié

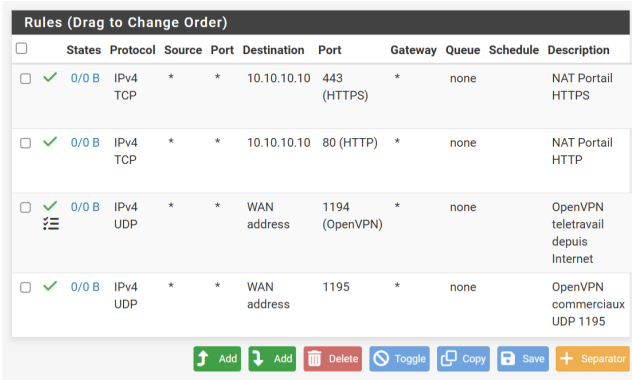
Un second serveur OpenVPN écoute en UDP 1195 avec le réseau 10.99.20.0/24, même méthode d'authentification (certificat + LDAP). Il ne donne accès qu'à la zone DEMO (10.10.40.0/24), jamais à la production, grâce à **deux barrières** : seule la route vers la zone DEMO est annoncée au client, et une règle de pare-feu journalisée bloque tout autre destination, même si le client force une route.



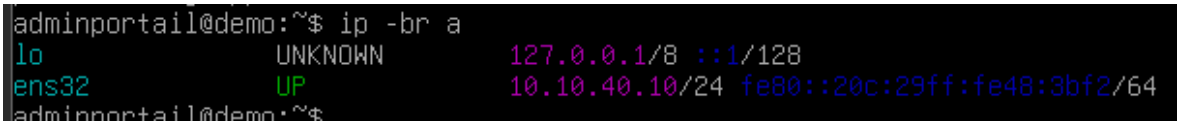
Capture 81 : System > Certificates : certificats utilisateurs alice.support, bob.compta, carl.it et dave.commercial (CN identique à l'identifiant LDAP), signés par MediConnect-CA



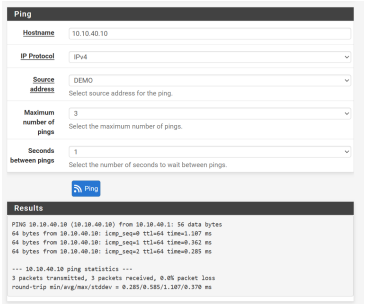
Capture 82 : VPN > OpenVPN > Servers : deux serveurs Remote Access (SSL/TLS + User Auth), « Teletravail MediConnect » UDP 1194 / 10.99.10.0/24 et « Commerciaux MediConnect » UDP 1195 / 10.99.20.0/24, AES-256-GCM, SHA256



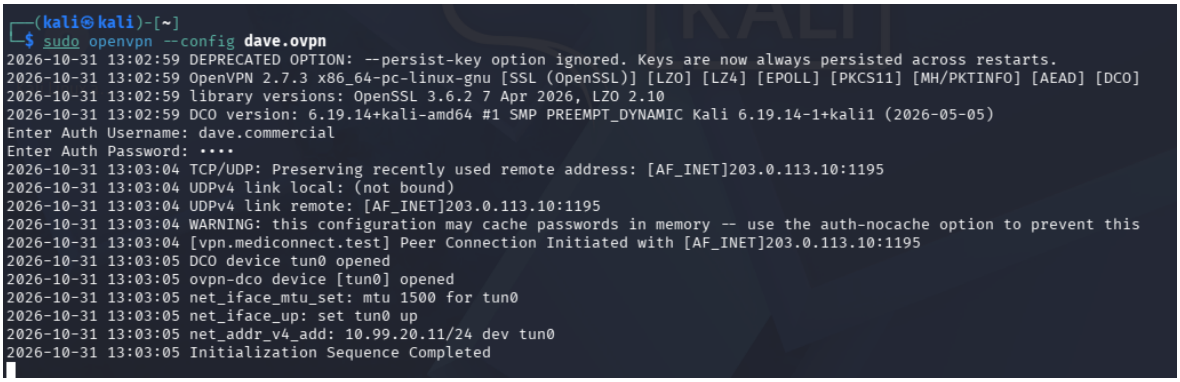
Capture 84 : Règles WAN : Pass TCP 443 et 80 vers le portail, Pass UDP 1194 (OpenVPN télétravail) et Pass UDP 1195 (OpenVPN commerciaux) vers l'adresse WAN



Capture 87 : Console de la VM Debian-DEMO (hostname demo) : ens32 en 10.10.40.10/24 dans la zone DEMO



Capture 88 : Diagnostics > Ping de pfSense (source DEMO 10.10.40.1) vers la VM DEMO 10.10.40.10 : 3 paquets reçus, 0 % de perte



Capture 89 : Kali : connexion OpenVPN de dave.commercial sur le serveur Commerciaux (UDP 1195), « Initialization Sequence Completed », adresse tunnel 10.99.20.11



Capture 90 : dave via VPN : DEMO 10.10.40.10 port 443 OUVERT ; CRM et portail inaccessibles (aucune route poussée vers ces réseaux, première barrière)



Capture 91 : dave via VPN avec routes forcées vers le CRM et le portail : DEMO 443 OUVERT, CRM et portail BLOQUE sans réponse (deuxième barrière : règle de pare-feu)

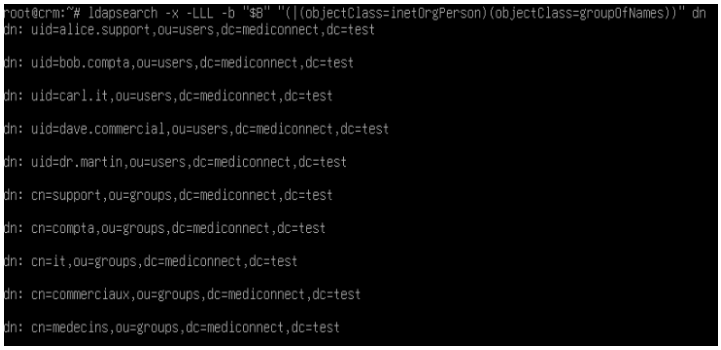


Capture 92 : Log pare-feu (ovpns2) : 10.99.20.11 vers 10.10.30.10:443 (CRM) et 10.10.10.10:443 (portail) bloqués par la règle « VPN commerciaux vers autres reseaux interdit »

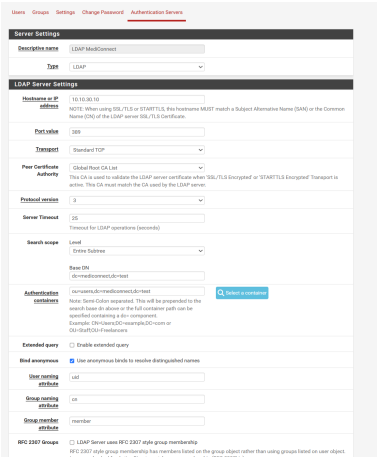
6. Mécanismes d'authentification

L'authentification est adaptée à chaque population et jamais fondée sur un seul secret.

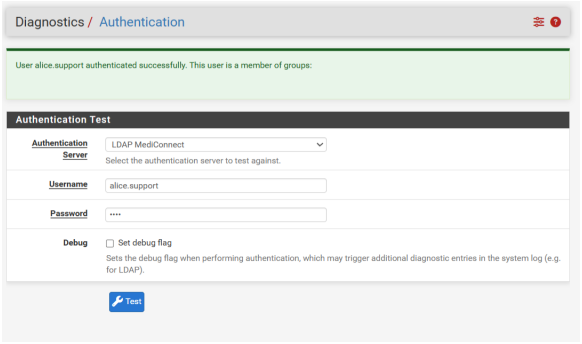
Population / flux	Mécanisme	Où
Employés en télétravail	Certificat client + mot de passe LDAP (double facteur : possession et connaissance)	OpenVPN
Site secondaire	Clé pré-partagée mutuelle, IKEv2	IPsec
Annuaire	OpenLDAP : 5 utilisateurs, 5 groupes (support, compta, it, commerciaux, medecins)	Serveur interne
Certificats	Autorité interne MediConnect-CA (validité 10 ans), certificats serveur et utilisateurs	pfSense
Base de données	Compte « portail » limité à l'adresse 10.10.10.10, droits SELECT, INSERT, UPDATE	MariaDB
Médecins	Certificat client signé par MediConnect-CA + mot de passe, sur le site pro	Portail, HTTPS



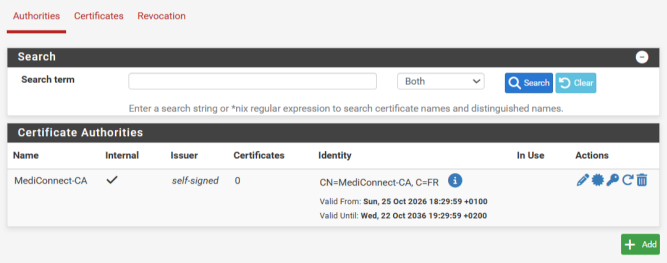
Capture 29 : Annuaire OpenLDAP de MediConnect (dc=mediconnect,dc=test) : 5 utilisateurs (alice.support, bob.compta, carl.it, dave.commercial, dr.martin) et 5 groupes (support, compta, it, commerciaux, medecins)



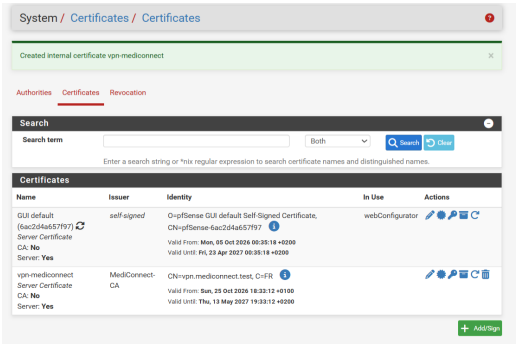
Capture 59 : System > User Manager > Authentication Servers de pfSense-SIEGE : serveur « LDAP MediConnect » (10.10.30.10, port 389 TCP, protocole 3), Base DN dc=mediconnect,dc=test, conteneur ou=users, liaison anonyme pour résoudre les DN, attribut uid, groupes par cn / member



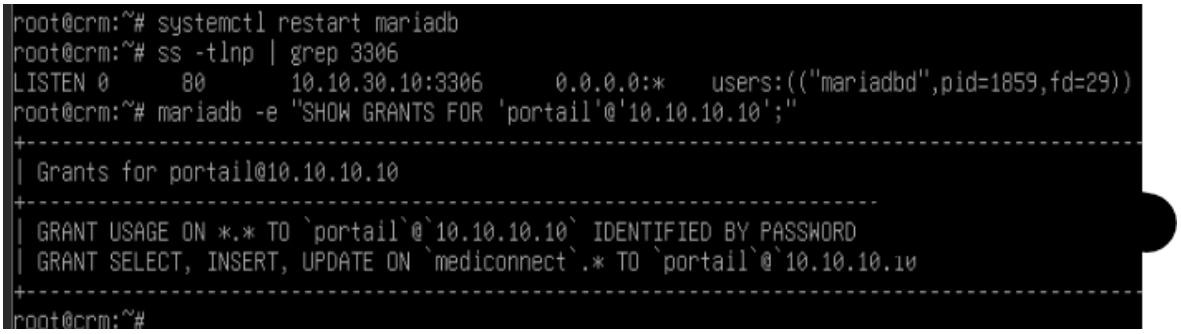
Capture 60 : Diagnostics > Authentication de pfSense-SIEGE : l'utilisateur alice.support est authentifié avec succès auprès du serveur « LDAP MediConnect » (mot de passe masqué). La liste de groupes est vide : l'appartenance aux groupes n'est pas lue (requête étendue désactivée), les droits par groupe passeront par des réglages par utilisateur



Capture 61 : System > Certificates > Authorities de pfSense-SIEGE : autorité de certification interne MediConnect-CA (auto-signée, CN=MediConnect-CA, C=FR), valide du 25/10/2026 au 22/10/2036



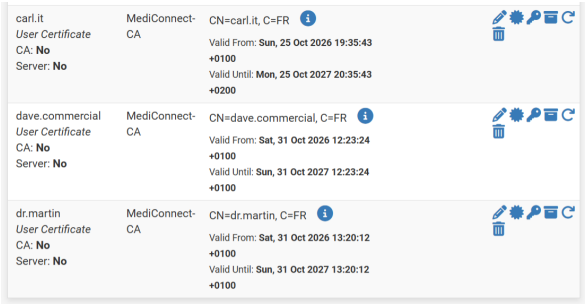
Capture 62 : System > Certificates > Certificates de pfSense-SIEGE : certificat du serveur VPN « vpn-mediconnect » (CN=vpn.mediconnect.test, Server Certificate, signé par MediConnect-CA, valide jusqu'au 13/05/2027), à côté du certificat par défaut de l'interface web



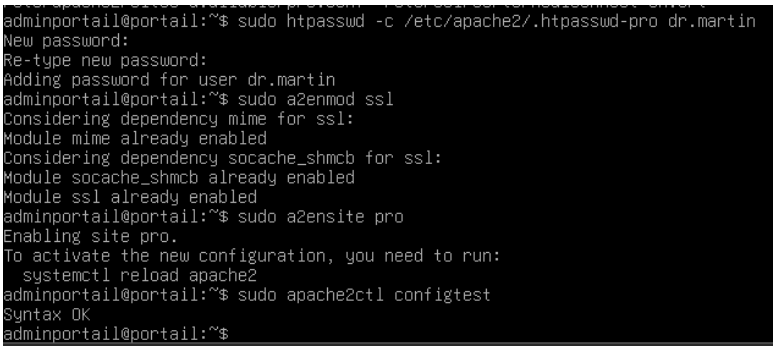
Capture 26 : Serveur interne : MariaDB écoute sur 10.10.30.10:3306, compte « portail » limité à l'adresse 10.10.10.10 avec les droits SELECT, INSERT, UPDATE sur la base mediconnect (hachage du mot de passe masqué)

Accès renforcé des médecins (certificat client)

Les médecins accèdent à un site professionnel distinct (pro.mediconnect.test) hébergé sur le portail. Le serveur Apache exige un certificat client signé par MediConnect-CA (SSLVerifyClient require) : sans certificat valide, la connexion est refusée avant toute page ; avec le certificat, un mot de passe est ensuite demandé. Un patient, qui n'a pas de certificat, ne peut donc pas atteindre ce site.



Capture 93 : System > Certificates : certificat utilisateur dr.martin (CN=dr.martin, signé par MediConnect-CA, valide un an), à côté de carl.it et dave.commercial



Capture 94 : Portail : mot de passe créé pour dr.martin (htpasswd), activation du site pro, apache2ctl configtest : Syntax OK

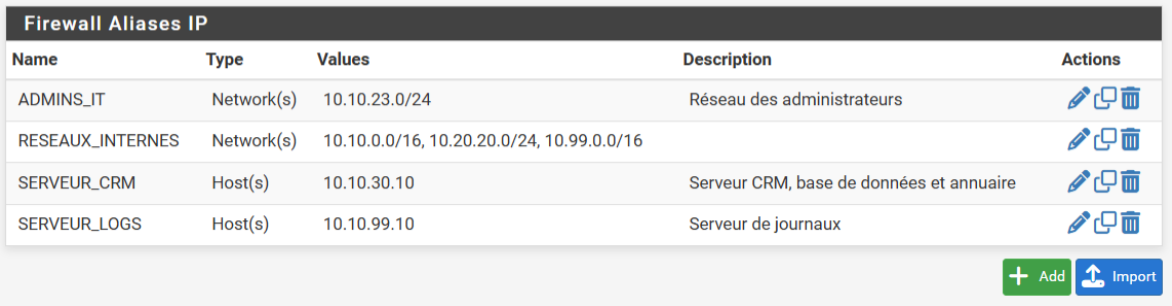


Capture 95 : Accès médecin à pro.mediconnect.test depuis Internet : sans certificat code 000 (connexion refusée), avec certificat sans mot de passe code 401, avec certificat et mot de passe page de l'espace professionnel affichée

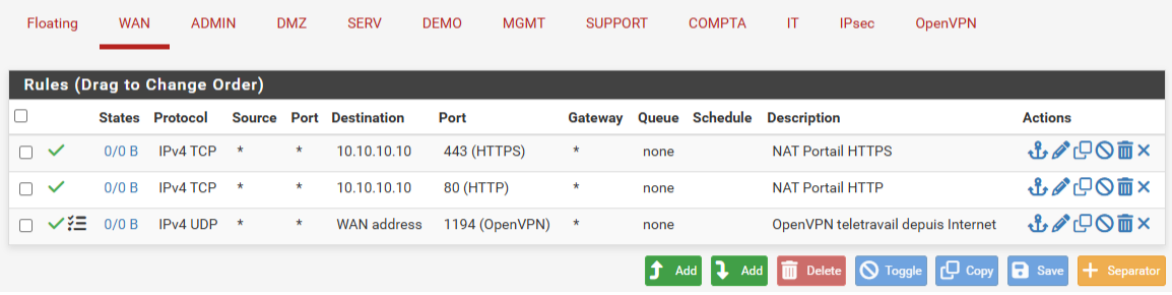
7. Politique de filtrage

pfSense évalue les règles **à l'entrée de chaque interface**, dans l'ordre, et applique la première qui correspond ; tout ce qui n'est pas expressément autorisé est refusé. Les règles de blocage importantes sont journalisées. Des alias (RESEAUX_INTERNES, SERVEUR_CRM, SERVEUR_LOGS, ADMINS_IT) rendent les règles lisibles et évitent les erreurs d'adresse.

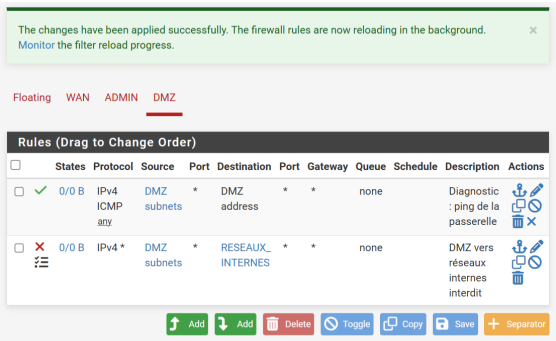
Interface	Autorisé	Refusé
WAN	TCP 443 et 80 vers le portail, UDP 1194 et 1195 (OpenVPN)	Tout le reste, ping compris
DMZ	TCP 3306 vers le CRM, ICMP vers la passerelle	Tout le reste vers les réseaux internes (journalisé)
SUPPORT, COMPTA	TCP 443 vers le CRM	Tout autre flux vers les réseaux internes (journalisé)
IT	TCP 443 et 22 vers le CRM	Tout autre flux vers les réseaux internes (journalisé)
IPsec (site 2)	TCP 443 vers le CRM	Tout le reste
OpenVPN télétravail	TCP 443 pour 3 profils, TCP 22 pour IT	Réseau VPN vers réseaux internes (journalisé)
OpenVPN commerciaux	TCP 443 vers la zone DEMO uniquement	Tout le reste (journalisé)
MGMT	Réception des journaux (UDP 514) depuis le pare-feu	Aucun accès depuis les zones utilisateurs



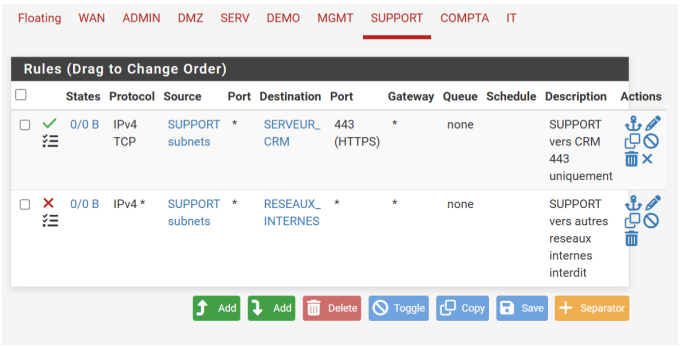
Capture 23 : Firewall > Aliases : ADMINS_IT (10.10.23.0/24), RESEAUX_INTERNES (10.10.0.0/16, 10.20.20.0/24, 10.99.0.0/16), SERVEUR_CRM (10.10.30.10), SERVEUR_LOGS (10.10.99.10)



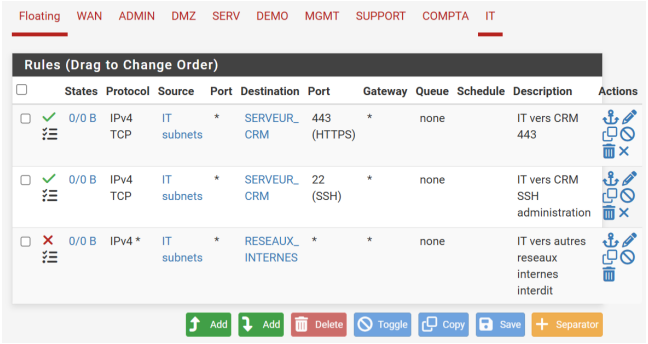
Capture 68 : Règles de l'interface WAN de pfSense-SIEGE : Pass TCP 443 et 80 vers le portail 10.10.10.10 (règles associées à la redirection NAT) et Pass UDP 1194 vers l'adresse WAN (OpenVPN télétravail) ; tout le reste est refusé par défaut



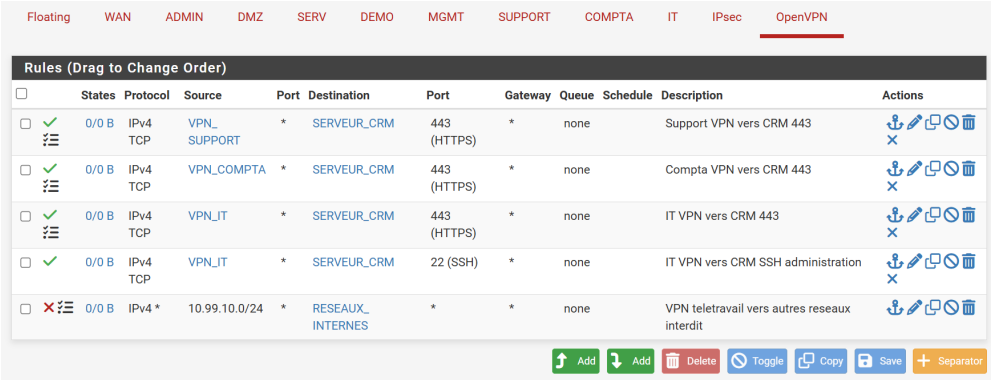
Capture 11 : Règles de l'interface DMZ : Pass ICMP vers la passerelle (diagnostic), puis Block (journalisé) de la DMZ vers l'alias RESEAUX_INTERNES ; le reste est refusé par défaut



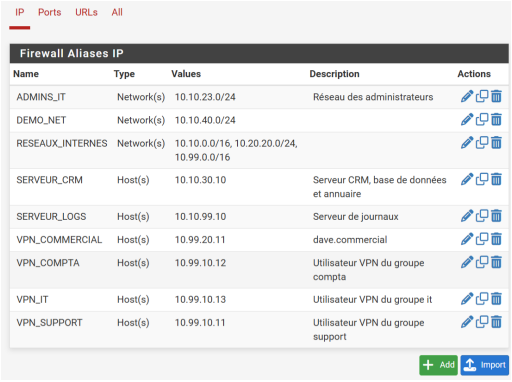
Capture 31 : Règles de la zone SUPPORT : Pass TCP vers SERVEUR_CRM port 443 uniquement, puis Block (journalisé) vers RESEAUX_INTERNES ; le reste est refusé par défaut



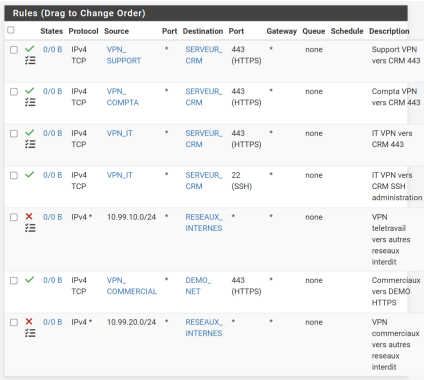
Capture 33 : Règles de la zone IT : Pass TCP vers SERVEUR_CRM ports 443 (HTTPS) et 22 (SSH administration), puis Block (journalisé) vers RESEAUX_INTERNES



Capture 72 : Règles de l'onglet OpenVPN de pfSense-SIEGE : Pass TCP 443 vers SERVEUR_CRM pour VPN_SUPPORT, VPN_COMPTA et VPN_IT ; Pass TCP 22 pour VPN_IT uniquement ; Block (journalisé) du réseau VPN 10.99.10.0/24 vers RESEAUX_INTERNES ; le reste est refusé par défaut



Capture 85 : Firewall > Aliases > IP : VPN_COMMERCIAL (10.99.20.11), DEMO_NET (10.10.40.0/24), VPN_SUPPORT, VPN_COMPTA, VPN_IT, ADMINS_IT, RESEAUX_INTERNES, SERVEUR_CRM, SERVEUR_LOGS

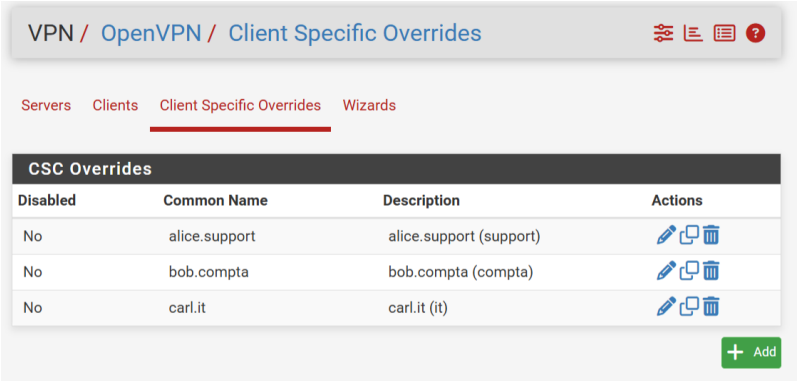


Capture 86 : Règles de l'onglet OpenVPN : profils télétravail, puis Pass TCP 443 de VPN_COMMERCIAL vers DEMO_NET uniquement, puis Block (journalisé) du réseau 10.99.20.0/24 vers RESEAUX_INTERNES

8. Règles basées sur l'identité

pfSense ne sait pas filtrer directement sur un groupe LDAP. L'identité est donc ramenée à une adresse : l'authentification LDAP et le certificat identifient l'utilisateur à la connexion, puis un paramétrage individuel lui attribue toujours la même adresse VPN. Un alias nommé (VPN_SUPPORT, VPN_COMPTA, VPN_IT) représente chaque profil et les règles s'écrivent sur ces alias.

Utilisateur	Groupe	Adresse VPN	Droits vers le serveur interne
alice.support	support	10.99.10.11	HTTPS (443)
bob.compta	compta	10.99.10.12	HTTPS (443)
carl.it	it	10.99.10.13	HTTPS (443) et SSH (22)
dave.commercial	commerciaux	10.99.20.11	Zone DEMO uniquement



Capture 69 : VPN > OpenVPN > Client Specific Overrides : réglages individuels pour alice.support (support), bob.compta (compta) et carl.it (it), qui leur attribuent une adresse VPN fixe

IP Ports URLs All

Firewall Aliases IP

Name	Type	Values	Description	Actions
ADMINS_IT	Network(s)	10.10.23.0/24	Réseau des administrateurs	
RESEAUX_INTERNES	Network(s)	10.10.0.0/16, 10.20.20.0/24, 10.99.0.0/16		
SERVEUR_CRM	Host(s)	10.10.30.10	Serveur CRM, base de données et annuaire	
SERVEUR_LOGS	Host(s)	10.10.99.10	Serveur de journaux	
VPN_COMPTA	Host(s)	10.99.10.12	Utilisateur VPN du groupe compta	
VPN_IT	Host(s)	10.99.10.13	Utilisateur VPN du groupe it	
VPN_SUPPORT	Host(s)	10.99.10.11	Utilisateur VPN du groupe support	

Add Import

Capture 70 : Firewall > Aliases > IP de pfSense-SIEGE : VPN_SUPPORT (10.99.10.11), VPN_COMPTA (10.99.10.12), VPN_IT (10.99.10.13), avec ADMINS_IT, RESEAUX_INTERNES, SERVEUR_CRM et SERVEUR_LOGS

```
┌──(kali㉿kali)-[~]
└─$ ip -br a show tun0
tun0             UP             10.99.10.11/24 fe80::5840:2bc4:5d:131e/64

┌──(kali㉿kali)-[~]
└─$ for p in 443 22 3306; do
echo -n "alice vers CRM port $p : "
timeout 3 bash -c "</dev/tcp/10.10.30.10/$p" && echo OUVERT || echo BLOQUE
done
alice vers CRM port 443 : OUVERT
alice vers CRM port 22 : BLOQUE
alice vers CRM port 3306 : BLOQUE
```

Capture 76 : alice (Support) via VPN : 443 vers CRM OUVERT, 22 et 3306 BLOQUE

```
┌──(kali㉿kali)-[~]
└─$ ip -br a show tun0
tun0             UP             10.99.10.13/24 fe80::d009:aaa2:428b:6557/64

┌──(kali㉿kali)-[~]
└─$ for p in 443 22 3306; do
   echo -n "carl vers CRM port $p : "
   timeout 3 bash -c "</dev/tcp/10.10.30.10/$p" && echo OUVERT || echo BLOQUE
   done
carl vers CRM port 443 : OUVERT
carl vers CRM port 22 : OUVERT
carl vers CRM port 3306 : BLOQUE
```

Capture 78 : carl (IT) via VPN : 443 et 22 vers CRM OUVERT, 3306 BLOQUE (contraste avec alice)

✕	Oct 26 21:29:07	ovpns1	VPN teletravail vers autres reseaux interdit (1793037803)	10.99.10.13:37618	10.10.30.10:3306	TCP:S
✕	Oct 26 21:29:08	ovpns1	VPN teletravail vers autres reseaux interdit (1793037803)	10.99.10.13:37618	10.10.30.10:3306	TCP:S
✕	Oct 26 21:29:09	ovpns1	VPN teletravail vers autres reseaux interdit (1793037803)	10.99.10.13:37618	10.10.30.10:3306	TCP:S

Capture 80 : Log pare-feu : 10.99.10.13 vers 10.10.30.10:3306 bloqué par la règle « VPN teletravail vers autres reseaux interdit » (interface ovpns1)

Servers Clients Client Specific Overrides Wizards Client Export

CSC Overrides

Disabled	Common Name	Description	Actions
No	alice.support	alice.support (support)	
No	bob.compta	bob.compta (compta)	
No	carl.it	carl.it (it)	
No	dave.commercial	dave.commercial - commerciaux - 10.99.20.11	

Add

Capture 83 : VPN > OpenVPN > Client Specific Overrides : alice.support, bob.compta, carl.it et dave.commercial (adresse fixe 10.99.20.11, commerciaux)

9. Contrôle applicatif

Le contrôle applicatif est mis en oeuvre par **filtrage des ports et des protocoles autorisés par profil** : chaque population n'atteint que le service dont elle a besoin (HTTPS pour le CRM, SSH pour l'équipe IT, 3306 réservé au portail). Les tests de ports par zone montrent que seuls les services prévus répondent.

Au niveau de l'application, plusieurs protections complètent ce filtrage : redirection systématique du HTTP vers le HTTPS, version d'Apache masquée, accès au site des médecins conditionné à un certificat client puis à un mot de passe (section 6), et compte de base de données limité à son adresse et à des droits minimaux. Ces mesures réduisent la surface d'attaque, mais ne remplacent pas un moteur d'inspection (IDS/IPS ou pare-feu applicatif), présenté en limite.



Capture 35 : Test depuis la zone SUPPORT (Kali en 10.10.21.50) : le port 443 du serveur CRM est OUVERT ; les ports 22, 80 et 3306 du CRM et le port 443 de la DMZ sont BLOQUES

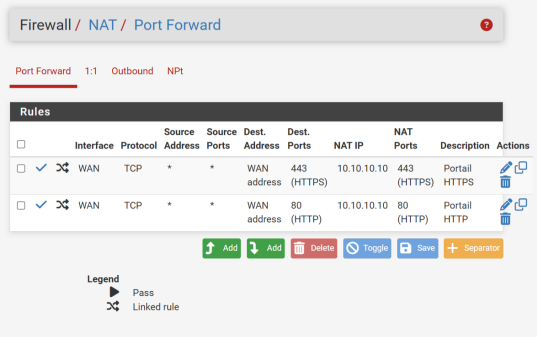


Capture 41 : Test depuis la zone IT (Kali en 10.10.23.50) : les ports 443 (HTTPS) et 22 (SSH) du serveur CRM sont OUVERTS ; les ports 80 et 3306 du CRM et le port 443 de la DMZ sont BLOQUES

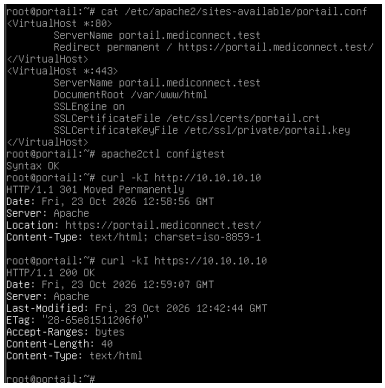
10. Protection de la DMZ

Le portail est le seul service exposé à Internet. Il est protégé à plusieurs niveaux :

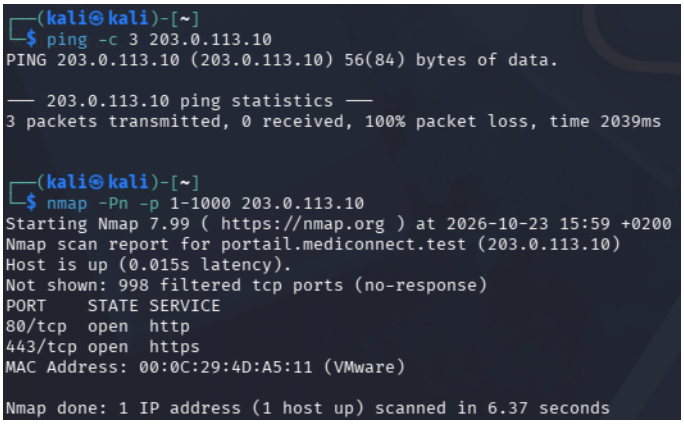
- accès uniquement en HTTPS : le port 80 ne fait que rediriger vers le port 443, la version d'Apache est masquée ;
- depuis Internet, seuls les ports 80 et 443 sont visibles, le ping vers le pare-feu est sans réponse ;
- la DMZ ne peut atteindre aucun réseau interne, à l'exception du port 3306 de la base de données et uniquement pour le portail ;
- le compte de base de données du portail est limité à son adresse et à des droits minimaux, sans droit d'administration ;
- toute tentative de sortie de la DMZ vers l'interne est bloquée et journalisée.



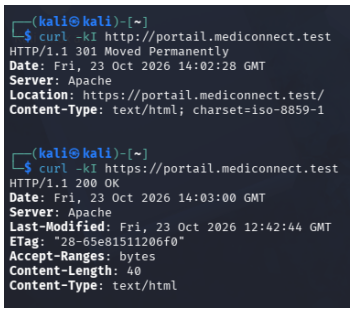
Capture 17 : Firewall > NAT > Port Forward : WAN 443 et 80 redirigés vers le portail 10.10.10.10 (règles de filtrage associées)



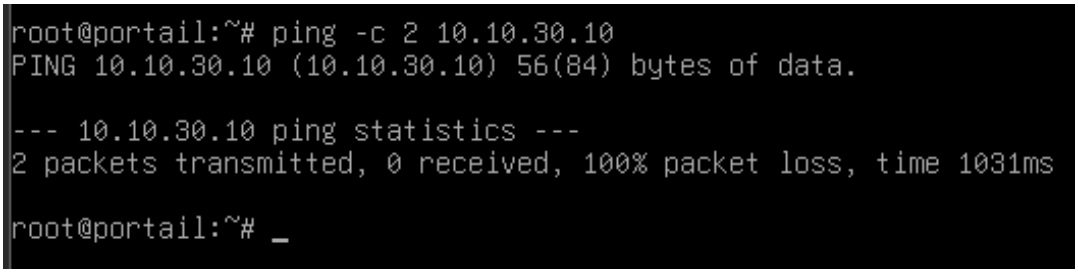
Capture 10 : Portail MediConnect : configuration Apache (redirection HTTP vers HTTPS), Syntax OK, redirection 301 sur le port 80 et réponse 200 en HTTPS, version d'Apache masquée



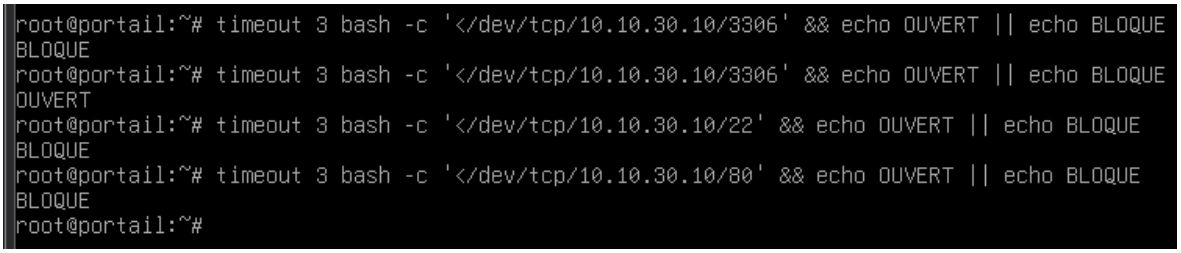
Capture 13 : Depuis Kali (Internet) : le ping vers le WAN de pfSense échoue (100 % de perte) et Nmap ne voit que les ports 80 et 443 ouverts (998 ports filtrés)



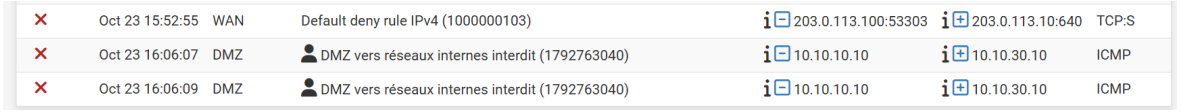
Capture 14 : Depuis Kali : le portail répond 301 sur HTTP (redirection vers HTTPS) puis 200 en HTTPS, via la redirection de ports du WAN



Capture 15 : Depuis le portail (DMZ) : le ping vers le réseau interne 10.10.30.10 reste sans réponse (100 % de perte)



Capture 28 : Depuis le portail : le port 3306 du serveur interne est BLOQUE avant la règle puis OUVERT après ; les ports 22 et 80 restent BLOQUE

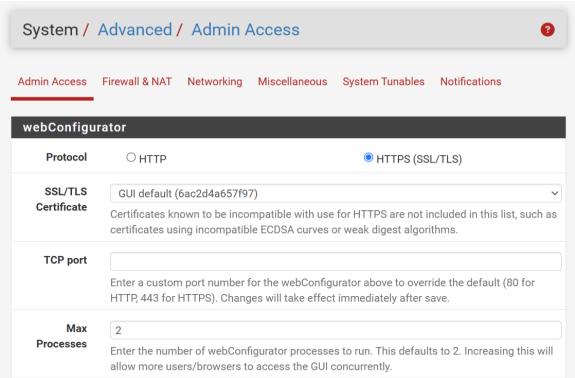


Capture 16 : Status > System Logs > Firewall : tentatives du portail vers 10.10.30.10 bloquées par la règle « DMZ vers réseaux internes interdit » ; ligne « Default deny » sur le WAN issue du scan Nmap de Kali

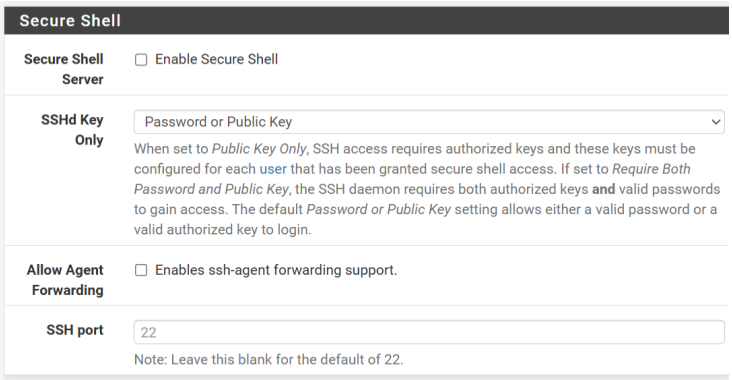
11. Sécurisation de l'administration

Les flux d'administration sont séparés des flux utilisateurs : l'interface web du pare-feu est servie en HTTPS sur une interface dédiée (ADMIN), et aucune zone utilisateur n'a de règle vers cette interface. Parmi les postes internes, seule la zone IT atteint le SSH du serveur interne. Un utilisateur connecté au LAN ne peut donc pas administrer directement les équipements.

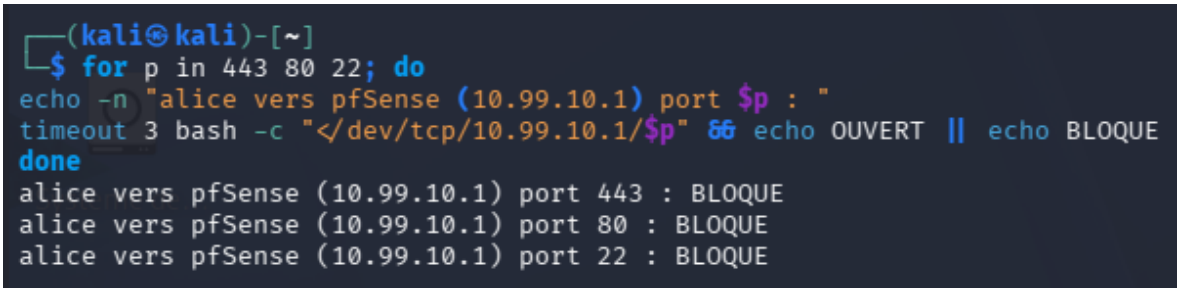
Le serveur web du pare-feu n'est servi qu'en HTTPS, le SSH du pare-feu est désactivé, et les utilisateurs VPN ne peuvent pas atteindre l'adresse du pare-feu. Depuis Internet, l'adresse WAN ne répond qu'avec la page du portail : l'interface d'administration n'est pas exposée.



Capture 101 : System > Advanced > Admin Access de pfSense-SIEGE : interface d'administration (webConfigurator) en HTTPS (SSL/TLS) uniquement



Capture 102 : System > Advanced > Admin Access : serveur SSH de pfSense désactivé (Enable Secure Shell non coché)



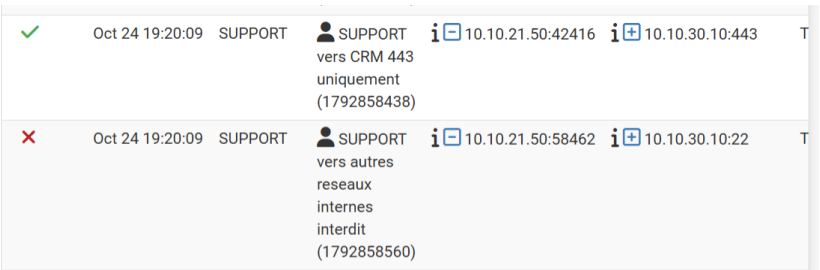
Capture 103 : alice via VPN vers l'adresse du pare-feu 10.99.10.1 : ports 443, 80 et 22 BLOQUE (un utilisateur ne peut pas administrer le pare-feu)



Capture 104 : Depuis Internet, l'adresse WAN du siège répond avec la page du portail (code 200, aucune occurrence de « pfsense ») : l'interface d'administration n'est pas exposée

12. Stratégie de journalisation

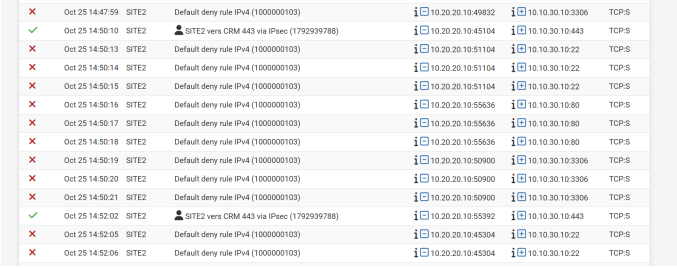
Les règles de blocage sensibles sont journalisées, ce qui permet de retrouver pour chaque événement la règle qui l'a décidé, la zone, la source et la destination. Les journaux du pare-feu montrent à la fois les flux autorisés et refusés, y compris sur le site secondaire et dans les tunnels VPN.



Capture 36 : Journal du pare-feu : 10.10.21.50 vers CRM 10.10.30.10:443 autorisé (règle « SUPPORT vers CRM 443 uniquement ») puis vers :22 bloqué (règle « SUPPORT vers autres reseaux internes interdit »)

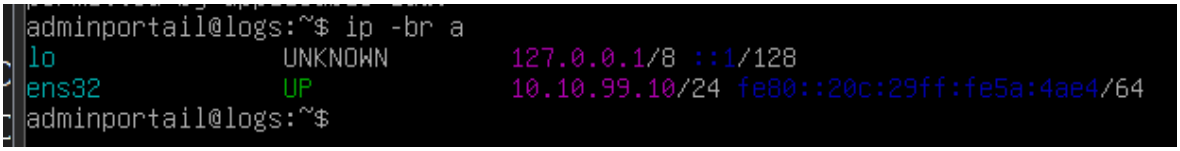


Capture 38 : Journal du pare-feu : 10.10.21.50 vers 10.10.30.10:3306 (MariaDB) bloqué par la règle SUPPORT vers autres réseaux internes

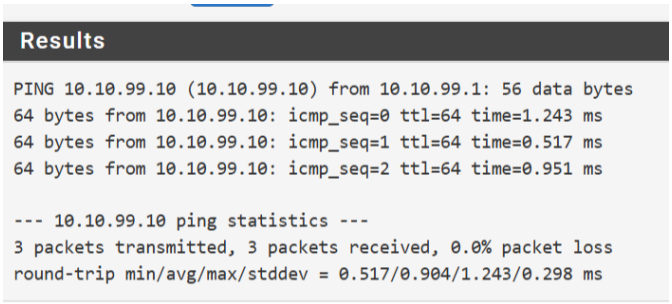


Capture 56 : Journal du pare-feu de pfSense-S2 : 10.20.20.10 vers le CRM 10.10.30.10:443 autorisé par la règle « SITE2 vers CRM 443 via IPsec » ; les ports 22, 80 et 3306 sont refusés par « Default deny rule » dès l'interface SITE2 (ils n'entrent jamais dans le tunnel)

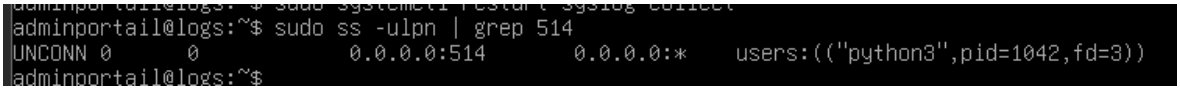
Centralisation. Une machine dédiée Debian-LOGS (10.10.99.10, zone MGMT) reçoit les journaux du pare-feu en syslog UDP 514. Faute de rsyslog disponible sur la maquette (sans accès Internet), un petit collecteur en Python, lancé comme service systemd, écrit les messages dans /var/log/pfsense-remote.log. Les journaux sont ainsi conservés hors du pare-feu, ce qui empêche un attaquant de les effacer en le compromettant.



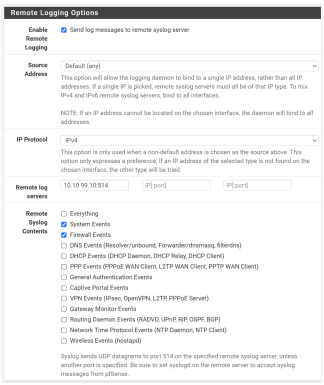
Capture 96 : Console de la VM Debian-LOGS (hostname logs) : ens32 en 10.10.99.10/24 dans la zone MGMT



Capture 97 : Diagnostics > Ping de pfSense (source MGMT 10.10.99.1) vers le serveur de journaux 10.10.99.10 : 3 paquets reçus, 0 % de perte



Capture 98 : Serveur de journaux Debian-LOGS : le collecteur syslog (python3, service systemd) écoute en UDP sur 0.0.0.0:514



Capture 99 : Status > System Logs > Settings de pfSense-SIEGE : journalisation distante activée vers 10.10.99.10:514 (UDP), événements système et pare-feu envoyés

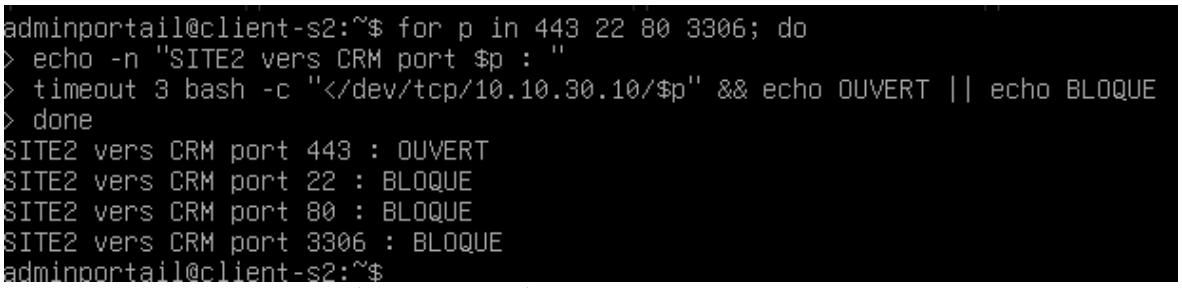
```
adminportail@logs:~$ sudo tail -5 /var/log/pfsense-remote.log
<134>Oct 31 14:54:52 filterlog[44874]: 1,6,,1000000103,em1,match,block,in,4,0x0,,64,59298,0,DF,6,tcp,60,203.0.113.100,203.0.113.10,50206,22,0,S,2968803655,,64
0,,mss;sackOK;TS;nop;wscale
<134>Oct 31 14:54:53 filterlog[44874]: 1,6,,1000000103,em1,match,block,in,4,0x0,,64,52706,0,DF,6,tcp,60,203.0.113.100,203.0.113.10,56738,23,0,S,2362729016,,64
0,,mss;sackOK;TS;nop;wscale
<134>Oct 31 14:54:54 filterlog[44874]: 1,6,,1000000103,em1,match,block,in,4,0x0,,64,52707,0,DF,6,tcp,60,203.0.113.100,203.0.113.10,56738,23,0,S,2362729016,,64
0,,mss;sackOK;TS;nop;wscale
<134>Oct 31 14:54:55 filterlog[44874]: 1,6,,1000000103,em1,match,block,in,4,0x0,,64,26733,0,DF,6,tcp,60,203.0.113.100,203.0.113.10,49522,3389,0,S,2637227222,,
240,,mss;sackOK;TS;nop;wscale
<134>Oct 31 14:54:56 filterlog[44874]: 1,6,,1000000103,em1,match,block,in,4,0x0,,64,26734,0,DF,6,tcp,60,203.0.113.100,203.0.113.10,49522,3389,0,S,2637227222,,
240,,mss;sackOK;TS;nop;wscale
adminportail@logs:~$ _
```

Capture 100 : Serveur de journaux Debian-LOGS : /var/log/pfsense-remote.log reçoit les événements du pare-feu (filterlog, action block) : 203.0.113.100 vers 203.0.113.10 ports 22, 23 et 3389 bloqués

13. Tests réalisés

Les tests sont conduits depuis Kali, placé tour à tour sur Internet, dans une zone interne ou dans un tunnel VPN, avec Nmap, des tests de ports et la lecture des journaux. Résultats validés à ce jour :

Test	Résultat attendu	Résultat	Captures
Nmap depuis Internet vers le WAN	Seuls 80 et 443 visibles, pas de ping	Conforme	13
Portail en HTTP puis HTTPS	301 puis 200	Conforme	14
DMZ vers réseau interne	Bloqué sauf 3306	Conforme	15, 28
Zones SUPPORT, COMPTA, IT vers CRM	443 ouvert (22 pour IT), 80 et 3306 bloqués	Conforme	35, 40, 41
Site 2 vers CRM par IPsec	443 ouvert, 22, 80, 3306 bloqués	Conforme	57, 58
Authentification LDAP	Bon mot de passe accepté, mauvais refusé	Conforme	30, 60
VPN télétravail : alice	443 ouvert, 22 et 3306 bloqués	Conforme	75, 76
VPN télétravail : carl	443 et 22 ouverts, 3306 bloqué	Conforme	77, 78
Journal d'un refus VPN	Ligne de blocage visible	Conforme	80
VPN commerciaux : dave	DEMO 443 ouvert ; CRM et portail bloqués (route absente, puis règle)	Conforme	89 à 92
Médecin : sans certificat / certificat seul / certificat + mot de passe	Refus, 401, accès	Conforme	95
Journaux centralisés	Blocages reçus sur Debian-LOGS	Conforme	100
Administration : HTTPS seul, SSH désactivé	Réglages actifs	Conforme	101, 102
Admin depuis VPN et depuis Internet	Ports du pare-feu bloqués ; WAN renvoie le portail	Conforme	103, 104



Capture 57 : Test depuis le site secondaire (client 10.20.20.10) à travers le tunnel IPsec : le port 443 du CRM est OUVERT ; les ports 22, 80 et 3306 sont BLOQUES

14. Limites de la solution

- **LDAP en clair** : la liaison entre pfSense et l'annuaire utilise le port 389 sans chiffrement (ni LDAPS ni STARTTLS). En production, LDAPS serait obligatoire.
- **Mots de passe de test** : volontairement simples pour la maquette ; une politique de mots de passe robustes et un second facteur dynamique (TOTP) seraient requis.
- **Contrôle applicatif par ports** : il ne distingue pas deux applications qui utilisent le même port et n'analyse pas le contenu. Un pare-feu nouvelle génération, ou un moteur d'inspection, couvrirait ce besoin.
- **Administration provisoire** : les pare-feux sont pilotés par une interface en NAT VMware et gardent leurs mots de passe par défaut pendant la maquette ; en production, un réseau d'administration dédié, des mots de passe forts et une authentification à second facteur seraient requis.

- **Clé pré-partagée IPsec** : l'authentification du tunnel repose sur un secret partagé ; des certificats, plus robustes et révocables, seraient préférables.
- **Patients** : le portail est public et aucun mécanisme d'authentification des patients n'est mis en place, l'application n'étant pas développée.
- **Pas de haute disponibilité** : un seul pare-feu par site et un seul serveur par rôle ; une panne coupe le service.
- **Maquette à échelle réduite** : Internet simulé, une machine par rôle, données fictives, pas de supervision externe ni de sauvegarde.
- **Collecteur de journaux minimal** : un script Python en UDP (non chiffré, sans rotation ni alerte) remplace un vrai serveur syslog ; en production, TLS, rotation et un SIEM seraient nécessaires.
- **Site pro des médecins** : il réutilise le certificat serveur du portail, d'où l'option -k dans les tests (nom de domaine de maquette).
- **Tunnel IPsec** : la zone MGMT n'est pas incluse dans la phase 2, les journaux du site 2 ne sont donc pas centralisés.
- **Identité par adresse** : la politique par utilisateur repose sur l'adresse VPN fixe attribuée à chaque compte ; elle est fiable tant que les attributions sont correctement maintenues.

Conclusion : l'infrastructure répond aux exigences du sujet. Chaque population dispose d'un accès adapté et authentifié, chaque zone est cloisonnée par un refus par défaut, les flux sont journalisés hors du pare-feu et les tests montrent que les accès non prévus sont bloqués. Les limites ci-dessus indiquent ce qu'il faudrait durcir pour une mise en production.